

# Информационная безопасность

Вводная лекция



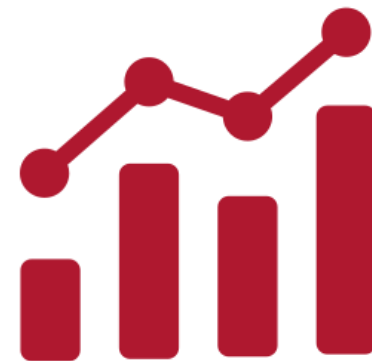
# Зачем вам этот курс?

- Знание основ ИБ пригодится в любой роли и ускорит карьерный рост
- Будете говорить на одном языке с командой безопасности, и вас будут слышать в собственной
- Курс может стать основой для старта или перехода в профессию ИБ
- Вы будете лучше разбираться в новостях об утечках, атаках и новых законах

# План лекции

- Статистика и контекст кибератак
- Базовый словарь
- Виды защищаемой информации
- Триада КЦД
- Направления ИБ и карта курса

# Статистика и контекст кибератак



# Статистика и контекст кибератак

+68%

рост числа атак  
на компании РФ <sup>1</sup>

<sup>1</sup> оценка  
Лаборатории Касперского  
на начало 2026 г.

до 250 млрд руб.

ущерб экономике  
от хакеров <sup>2</sup>

<sup>2</sup> в год  
по оценке Минцифры

62%

атак  
привели к нарушению  
деятельности <sup>3</sup>

<sup>3</sup> из успешных атак  
на веб-приложения  
по оценке РТ за 2025 г.



# 12STOREEZ ПОТЕРЯЛ ОКОЛО 48 МЛН РУБЛЕЙ ИЗ-ЗА КИБЕРАТАКИ

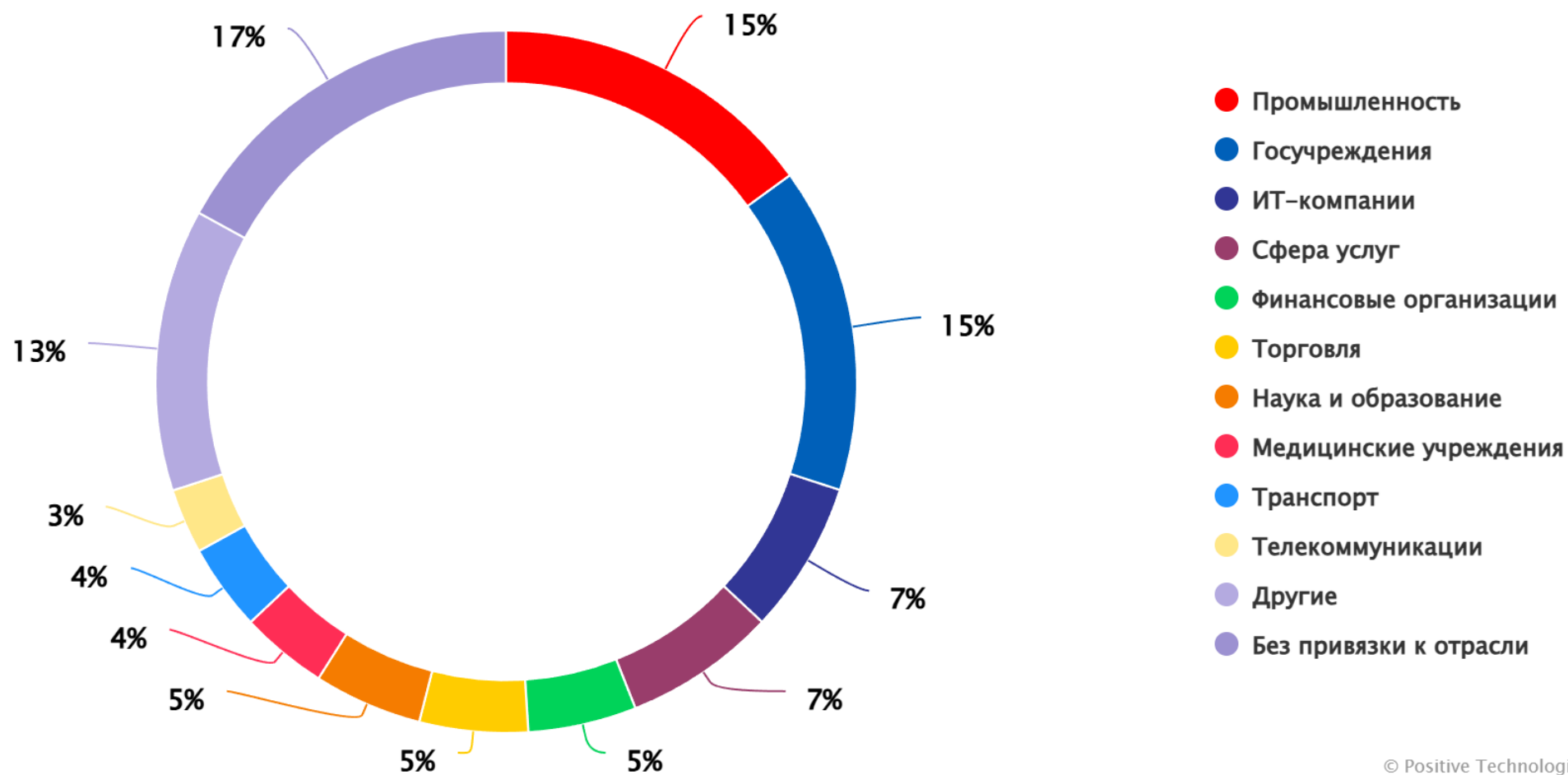
Бизнес · 29 июля 2025, 02:14

**«Аэрофлот» из-за IT-сбоя только за сутки, 28 июля, мог потерять не менее ₽250 млн из-за необходимости отмены рейсов в Шереметьево. С учетом расходов на восстановление инфраструктуры ущерб может быть больше**

31 июля 2026 19:21 Технологии

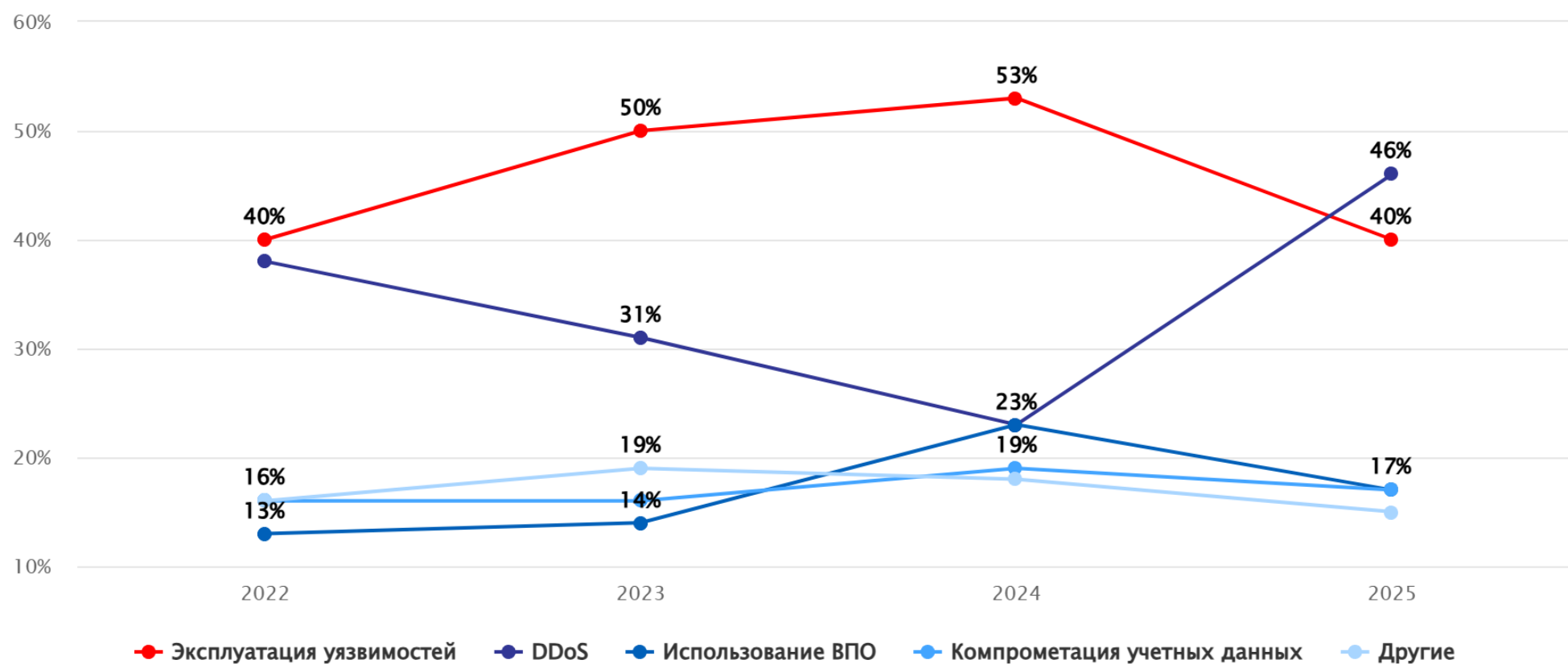
## Крупный российский банк подвергся мощной четырехдневной DDoS-атаке

# Жертвы кибератак



# Методы атак

Методы, использованные киберпреступниками в успешных атаках на веб-ресурсы



DDoS-атака - поток запросов с множества устройств, делающая сервис недоступным



# Базовый словарь

Уязвимость, угроза, риск, событие, инцидент, атака





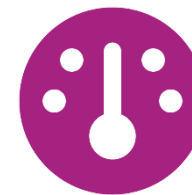
## Уязвимость

Где в системе  
есть слабое  
место?



## Угроза

Что плохого  
может  
произойти?



## Риск

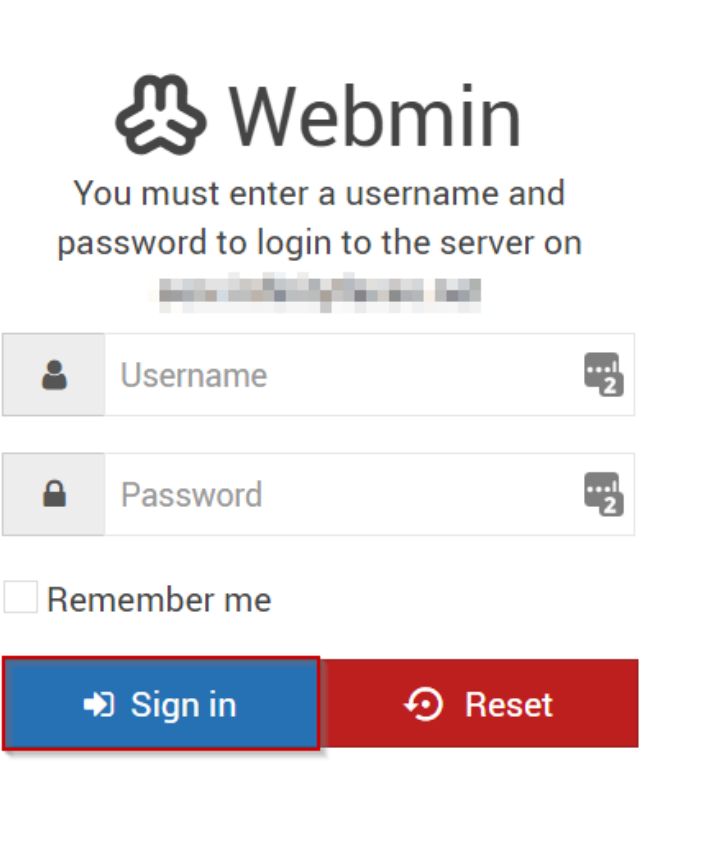
Насколько это  
реально и какой  
будет ущерб?

# Рассмотрим ситуацию

*Злоумышленник зашел в панель администрирования сервера, используя учетную запись по умолчанию.*

*Через панель он выполнил скрипт на сервере и выгрузил базу данных*

Определите из ситуации  
уязвимость, угрозу, риск



The image shows the Webmin login page. At the top, there is a Webmin logo and the text "You must enter a username and password to login to the server on [redacted]". Below this, there are two input fields: "Username" and "Password". Each field has a user icon on the left and a speech bubble icon with the number "2" on the right. Below the input fields, there is a checkbox labeled "Remember me". At the bottom, there are two buttons: a blue "Sign in" button and a red "Reset" button.

# Разбор ситуации

## Уязвимость

- дефолтный пароль администратора
- открытая в интернет панель администратора

## Угроза

возможность получения контроля над сервером и данными посторонним лицом

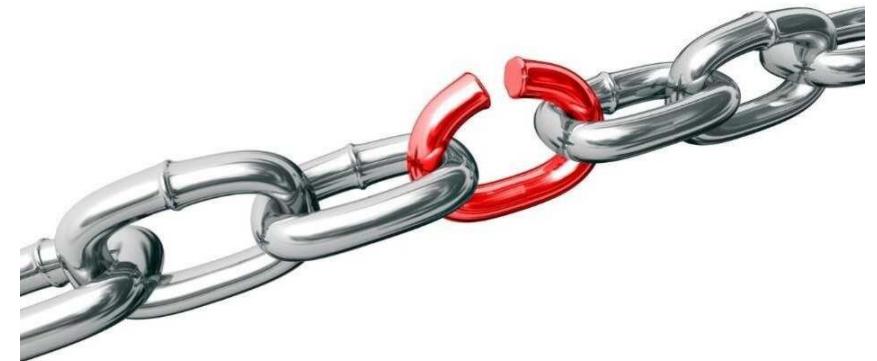
## Риск

- высокая вероятность (дефолтные пароли)
- серьезные последствия (утечка БД, остановка бизнес-процессов)

# Уязвимость

Уязвимость - недостаток системы, который может быть использован для нарушения ее безопасности

- Уязвимости могут скрываться в коде, бизнес-логике, конфигурации, инфраструктуре, средствах защиты
- Уязвимости оцениваются по уровню опасности:
  - Критические
  - Высокие
  - Средние
  - Низкие



# Уязвимость в антивирусе ESET

## 🌸 CVE-2021-37852 Detail

### Description

Продукты ESET для Windows позволяют недоверенным процессам выдавать себя за клиента канала связи, с помощью чего злоумышленник может повысить свои привилегии до NT AUTHORITY\SYSTEM (наивысший уровень привилегий в Windows) с помощью Windows Antimalware Scan Interface.

### Metrics

CVSS Version 4.0

**CVSS Version 3.x**

CVSS Version 2.0

*NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.*

#### CVSS 3.x Severity and Vector Strings:



**NIST:** NVD

**Base Score:** 7.8 HIGH

**Vector:** CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H



**CNA:** ESET

**Base Score:** 7.8 HIGH

**Vector:** CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

### QUICK INFO

#### CVE Dictionary Entry:

[CVE-2021-37852](#)

#### NVD Published Date:

Feb 09, 2022

#### NVD Last Modified:

Jun 17, 2026

#### Source:

ESET

# Угроза

Угроза безопасности информации  
– потенциальная опасность, которая может реализоваться при определенных условиях

## Примеры

- *Угроза утечки персональных данных пользователей через уязвимость в API*
- *Угроза недоступности сервиса в момент наибольшей нагрузки*
- *Угроза утраты данных и оборудования из-за пожара в серверной*



# Источники угроз

- Человек
  - Нарушитель – это лицо, действия которого направлены на нарушение безопасности системы, независимо от намерения
  - Злоумышленник – это нарушитель, осознанно совершающий действия, направленные на нарушение безопасности системы, с намерением причинить вред или получить выгоду
- Оборудование (программно-аппаратные средства)
- Природа (стихийные источники)





# Риск

Риск информационной безопасности  
– **потенциальная возможность** реализации угрозы ИБ  
для причинения ущерба

Ущерб – потеря (материальная, репутационная, юридическая),  
которую несет организация или физическое лицо

Риск характеризуется

- **вероятностью** реализации угрозы
- **стоимостью** потерь в случае реализации угрозы

# Риск - сочетание вероятности события и его последствий

## Пример

Угроза *компрометации базы данных* через *эксплуатацию уязвимости* в сторонней библиотеке, используемой в приложении

## Вероятность

- Уязвимость публично известна?
- Библиотека широко распространена?
- Приложение публично доступно из интернета?
- Эксплуатация требует сложных условий?

## Последствия

Регуляторный штраф, репутационный ущерб



# Атака

Атака – **попытка навредить системе**, нарушить ее работу или получить чужие данные

Атака не обязана быть успешной, чтобы считаться атакой

*Примеры*

- *DDoS-атака на сервис, чтобы сделать его недоступным для легитимных пользователей*
- *Эксплуатация уязвимости внедрения команд ОС в API с последующей выгрузкой базы данных*
- *Подбор пароля административной панели веб-приложения путем брутфорса*

# Событие и инцидент ИБ

## Событие ИБ

- зафиксированное **состояние системы**, которое может говорить о проблеме

```
[12/05/2026 13:05] Неудачная попытка входа: Login: <Ivanov> Попытка: 1  
[12/05/2026 13:06] Вход пользователя: Login: <Ivanov>
```

## Инцидент ИБ

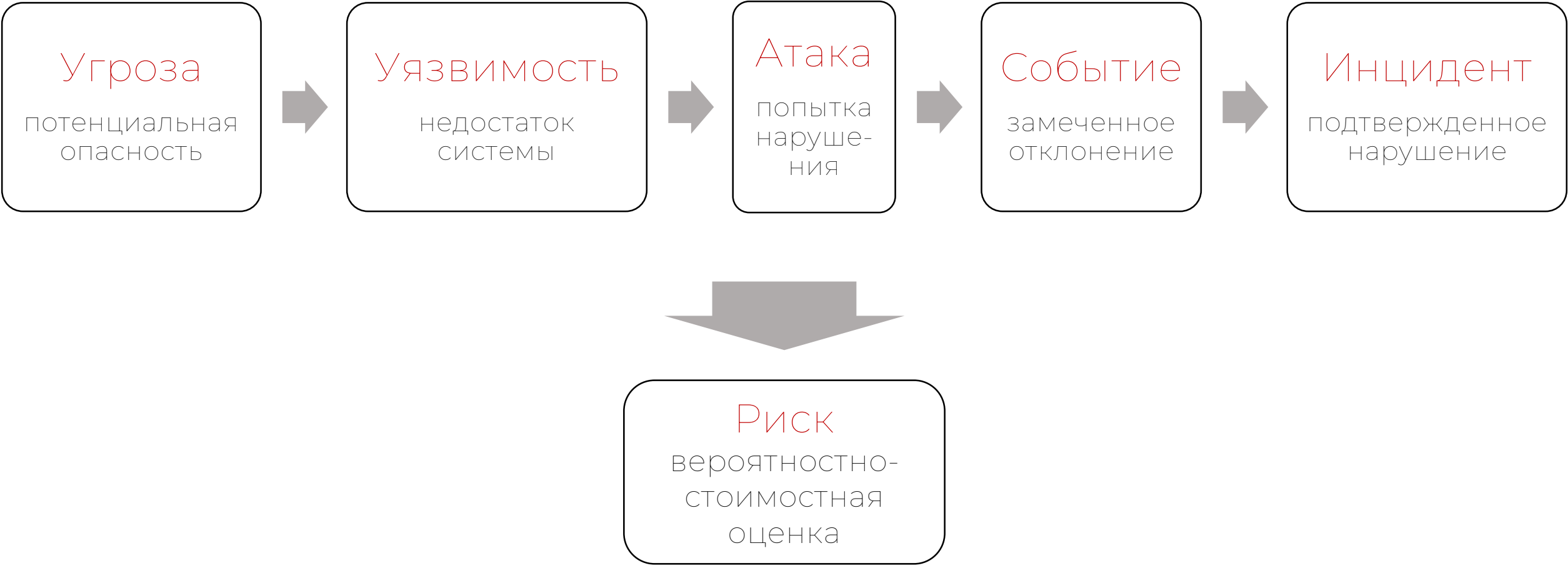
- событие ИБ, которое **привело к нарушению защищенности информации**, то есть к реализации угрозы

```
[12/05/2026 13:05] Неудачная попытка входа: Login: <Ivanov> Попытка: 18  
[12/05/2026 13:05] Неудачная попытка входа: Login: <Ivanov> Попытка: 19  
[12/05/2026 13:06] Неудачная попытка входа: Login: <Ivanov> Попытка: 20  
[12/05/2026 13:06] Вход пользователя: Login: <Ivanov>
```

# Инцидент

Инцидентами могут являться:

- утрата услуг, оборудования или устройств
- нарушение правил доступа
- несоблюдение политики или рекомендаций по ИБ
- неконтролируемые изменения систем
- сбои программного обеспечения и отказы технических средств
- нарушение физических мер защиты
- ...



Что защищаем



# Активы организации

- Информационные активы – код, документация, конфигурационные файлы, отчеты, регламенты
- Ресурсы – финансовые, людские, вычислительные и телекоммуникационные (серверы, сети, рабочие станции, облака)
- Процессы – сборка и установка приложения, обработка заказа, любая цепочка действий с данными
- Выпускаемая продукция и/или оказываемые услуги – само приложение, API, возможность оформить заказ



# КРИТИЧНОСТЬ АКТИВОВ

| Актив                                    | Категория                         | Критичность |
|------------------------------------------|-----------------------------------|-------------|
| База данных с историей операций клиентов | информационный актив              | ?           |
| Боевое веб-приложение                    | выпускаемая продукция             | ?           |
| CI/CD-пайплайн и секреты                 | процесс /<br>информационный актив | ?           |
| Логи приложения                          | информационный актив              | ?           |
| Внутренняя документация                  | информационный актив              | ?           |
| Сервер                                   | вычислительный ресурс             | ?           |

# КРИТИЧНОСТЬ АКТИВОВ

| Актив                                    | Категория                         | Критичность |
|------------------------------------------|-----------------------------------|-------------|
| База данных с историей операций клиентов | информационный актив              | Высокая     |
| Боевое веб-приложение                    | выпускаемая продукция             | Высокая     |
| CI/CD-пайплайн и секреты                 | процесс /<br>информационный актив | Высокая     |
| Логи приложения                          | информационный актив              | Средняя     |
| Внутренняя документация                  | информационный актив              | Низкая      |
| Сервер                                   | вычислительный ресурс             | Высокая     |

# Классификация защищаемой информации

- Персональные данные
  - ФИО, дата рождения, адрес, образование... (№152-ФЗ)
  - Платежные данные (PCI DSS)
- Коммерческая тайна (№98-ФЗ)
- Служебная тайна
- Профессиональная тайна
- Тайна изобретения
- Тайна следствия и судопроизводства

Указ Президента РФ № 188 «Об утверждении перечня сведений конфиденциального характера»



# «Защищенный актив»

Состояние защищенности информации

*Безопасность информации –  
состояние защищенности информации,  
при котором обеспечены  
ее конфиденциальность, доступность и целостность.*

ГОСТ Р 50922— 2006

# Конфиденциальность

Конфиденциальность – свойство информации оставаться **неизвестной** тем, у кого нет полномочий ее видеть

## Пример

*Веб-приложение записывает персональные данные клиента в продакшен-логи. Их видит вся команда, они хранятся месяцами и отправляются в сторонний сервис аналитики*

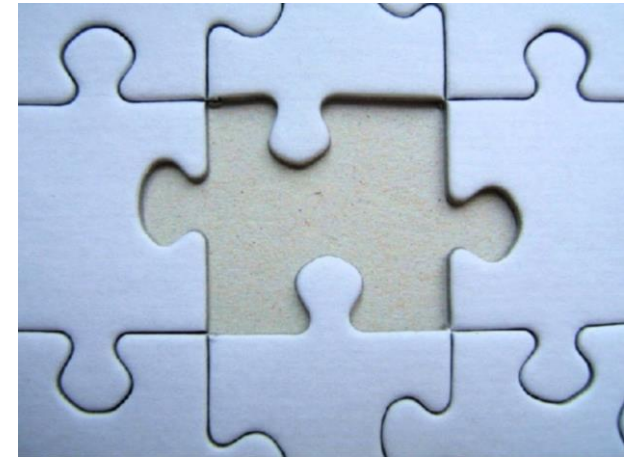


# Целостность

Целостность – свойство информации оставаться точной и неизменной, если ее не должны были менять

## *Пример*

*Инженер по ошибке применил бэкап базы данных недельной давности вместо вчерашнего. Теряются актуальные заказы клиентов*



# Доступность

Доступность – свойство информации быть доступной и готовой к использованию по легитимному запросу

## *Пример*

*Платежный шлюз, через который проходит оплата заказов, стал недоступен из-за DDoS-атаки на его инфраструктуру. Пользователи доходят до оформления заказа, но не могут завершить оплату*





Информационная безопасность обеспечивает  
конфиденциальность, доступность и целостность  
информации. Это достигается посредством  
внедрения соответствующих мер.

ГОСТ Р ИСО/МЭК 27000-2021

# Направления ИБ

Карта курса





## Red Team

Имитация действий  
атакующего  
на собственной системе:

- Разведка
- Пентест
- Социальная инженерия
- Написание эксплойтов



## Blue Team

Обнаружение,  
реагирование  
и защита от атак:

- Мониторинг
- Разбор инцидентов
- Настройка СЗИ
- Сканеры и правила



## Purple Team

Взаимодействие  
команд для улучшения  
защитных мер:

- Киберучения
- Создание playbooks
- Разбор инцидентов
- Оценка покрытия

# Карта курса

1. AppSec & DevSecOps
2. Сетевая безопасность
3. Аналитика и моделирование угроз
4. Безопасность инфраструктуры
5. Комплаенс

# AppSec

Направление деятельности по встраиванию процессов, инструментов и практик информационной безопасности на всех этапах жизненного цикла разработки

Будет рассмотрено:

- Роль AppSec инженера в организации
- Практики AppSec в SDLC, принцип Security by Design
- Классификация и базы данных уязвимостей
- Процесс управления уязвимостями

# DevSecOps

Направление деятельности по встраиванию процессов и инструментов безопасности в CI/CD для автоматизации выявления уязвимостей на всех этапах цикла разработки

Будет рассмотрено:

- Автоматизированные сканеры безопасности
- Встраивание инструментов в процесс разработки

# Сетевая безопасность

Направление деятельности по защите сетевой инфраструктуры и трафика организации от несанкционированного доступа, перехвата данных и атак на сетевом уровне.

Будет рассмотрено:

- Принципы построения безопасной сети, зоны безопасности
- Средства сетевой защиты
- Обнаружение и реагирование на инциденты ИБ сетевого уровня
- Защита от сетевых атак и инспекция трафика

# Аналитика и моделирование угроз

Направление деятельности по выявлению, анализу и приоритизации угроз и рисков для активов организации на основе данных об актуальном ландшафте атак и поведении злоумышленников

Будет рассмотрено:

- Тактики и техники атак на корпоративную инфраструктуру
- Моделирование угроз и управление рисками
- Анализ событий безопасности



# Безопасность инфраструктуры

Направление деятельности по защите контейнеризированных приложений, Kubernetes кластера и облачной инфраструктуры

Будет рассмотрено:

- Механизмы контейнеризации, принципы изоляции
- Архитектура оркестрации на примере k8s
- Риски безопасности и меры в контейнерных средах

# Комплаенс

Направление деятельности по обеспечению соответствия организации требованиям регуляторов, отраслевым стандартам и внутренним политикам информационной безопасности

Будет рассмотрено:

- Основные стандарты по ИБ
- COMPLAINT требования законодательства
- COMPLAINT требования отраслевых стандартов



# Для самостоятельного изучения

- [cybersecurity-roadmap.ru](https://cybersecurity-roadmap.ru) - схема карьерных треков в кибербезопасности
- «Киберугрозы веб-приложений и инфраструктуры разработки: тренды и прогнозы 2026–2027» - аналитическая статья о ландшафте общемировых киберугроз для веб-приложений и инфраструктуры разработки от РТ
- ГОСТ Р ИСО/МЭК 27000-2021 - базовые термины ИБ
- OWASP Top 10 - перечень наиболее распространенных угроз безопасности приложений (web, mobile, api, AI)

# Итог лекции

- С угрозами информационной безопасности сталкивается любая организация, которая обрабатывает данные
- Базовый словарь: уязвимость, угроза, риск, атака, событие, инцидент
- Защищенность данных - три свойства: конфиденциальность, целостность, доступность
- Задачи информационной безопасности распределены между несколькими направлениями, каждое со своей зоной ответственности - от кода до инфраструктуры и соответствия закону

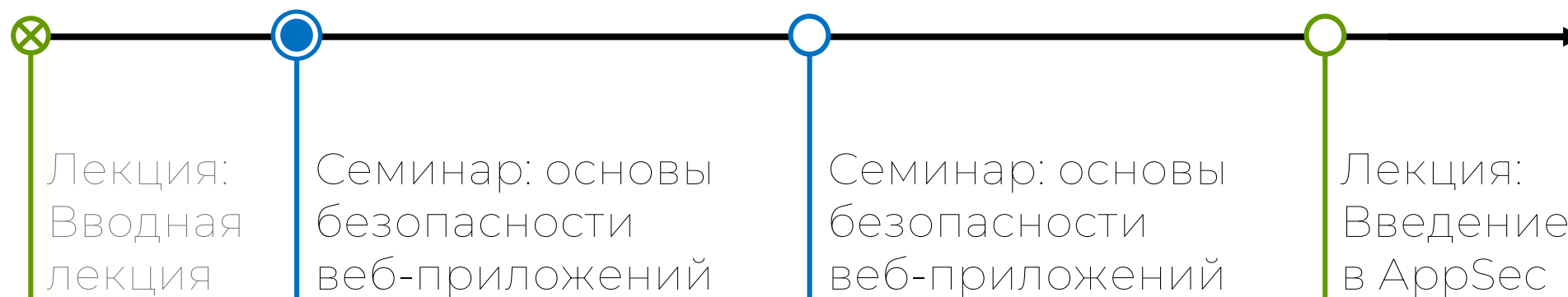


# Информационная безопасность

Вводная лекция



# Что будет дальше?





Материалы тут

<https://github.com/avnosenko/nsu-course>

